

RAPPORT DE TRAVAUX PRATIQUES

Suricata IDS/IPS sur pfSense

I. Introduction

L'objectif de ce TP était d'installer et de configurer Suricata sur pfSense afin de transformer le pare-feu en un système de détection et de prévention d'intrusions (IDS/IPS). Après avoir segmenté le réseau et contrôlé les flux, il s'agit maintenant d'analyser le comportement du trafic pour détecter des attaques.

II. Architecture du laboratoire

Machine	Rôle	Adresse IP
pfSense	Pare-feu + IDS/IPS	192.168.1.1 (LAN)
Ubuntu / Windows	Pare-feu + IDS/IPS	192.168.1.10 (Ubuntu)
Kali Linux	Attaquant (WAN simulé)	[IP WAN]

Tout le trafic destiné à Ubuntu transite obligatoirement par pfSense, ce qui permet à Suricata de l'inspecter

III. Étape 1 — Installation de Suricata sur pfSense

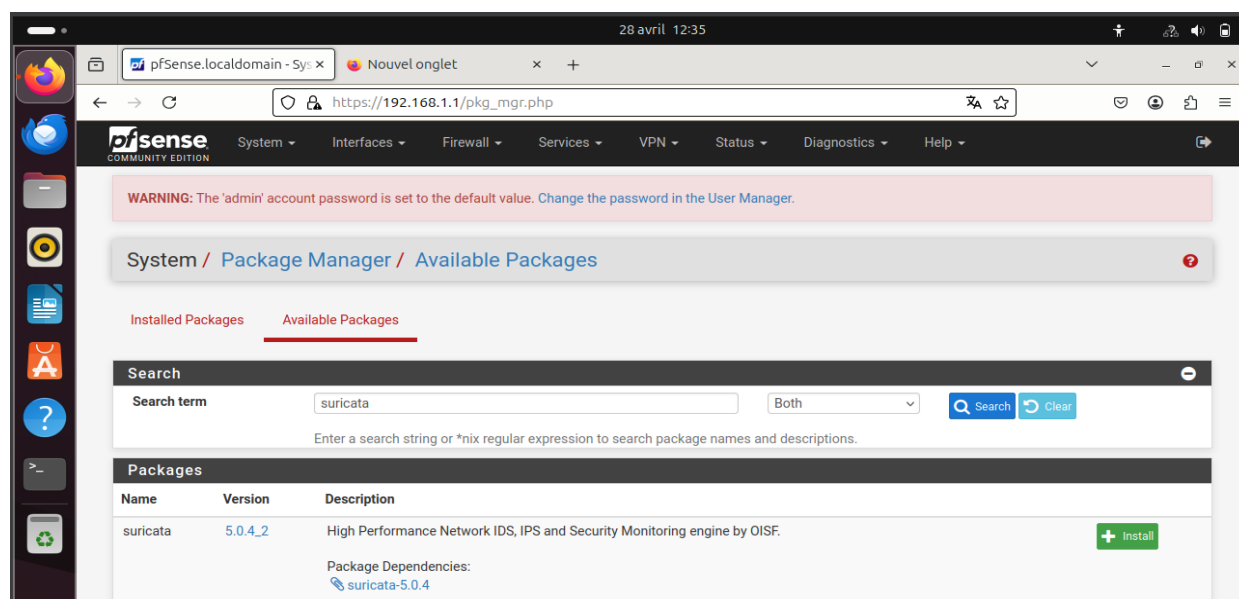
Depuis l'interface web pfSense :

System > Package Manager > Available Packages

Recherche : suricata

Installation du paquet pfSense-pkg-suricata

Capture d'écran — Installation de Suricata :

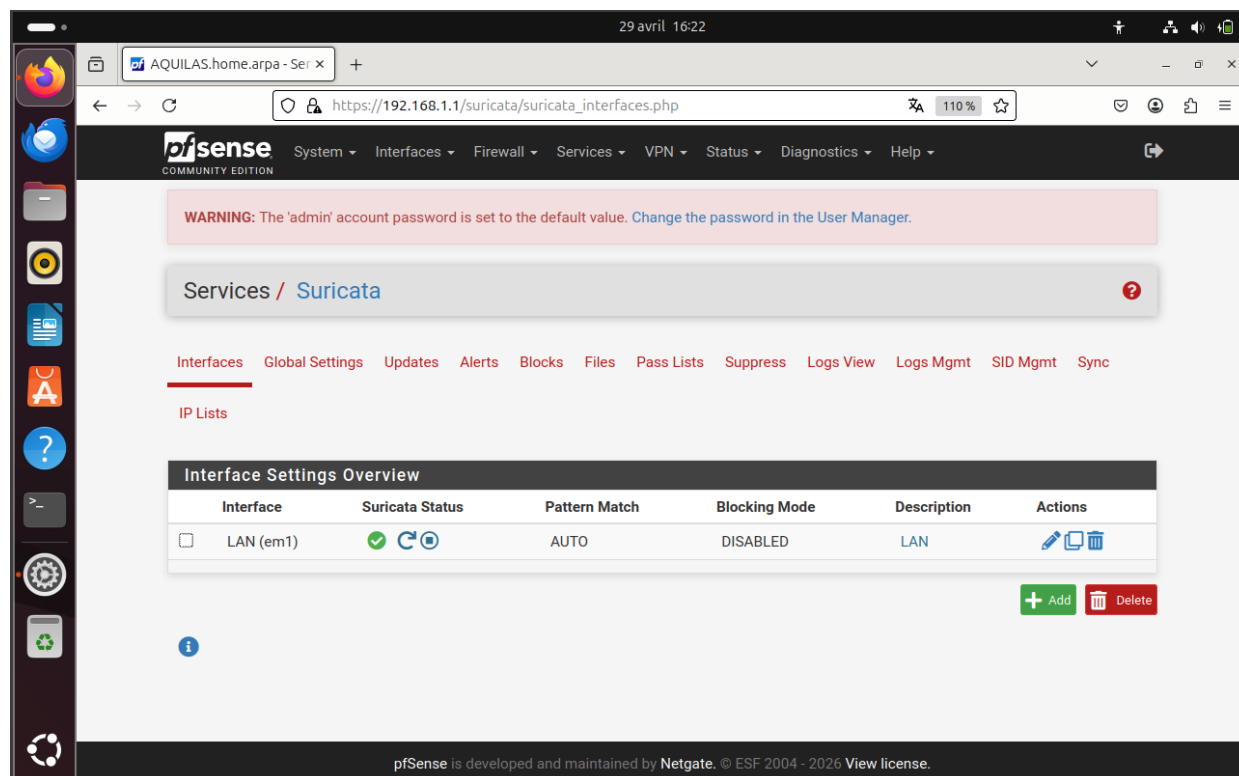


III. Étape 2 — Activation de Suricata sur l'interface LAN

Navigation : Services → Suricata

- Clic sur "Add" pour ajouter une nouvelle interface à surveiller
- Sélection de l'interface : LAN
- Enregistrement de la configuration

Capture d'écran — Activation de Suricata sur l'interface LAN :

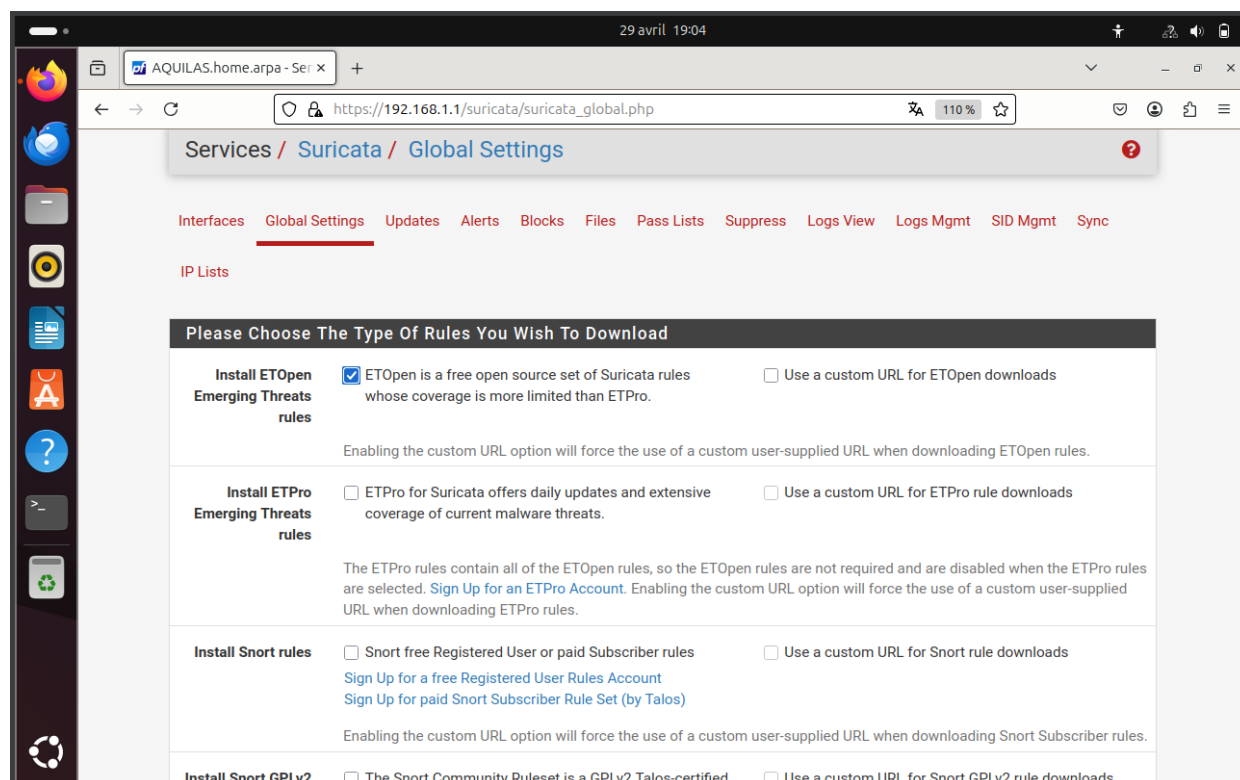


IV. Étape 3 — Activation des règles de détection

Dans Services > Suricata > Global Settings, nous avons activé les sources de règles suivantes :

Source	Utilité
ET Open Emerging Threats	Règles communautaires mises à jour
Snort GPLv2 Community	Règles certifiées Talos
Feodo Tracker C2 IP	Blocage des serveurs de botnets

Capture d'écran — Activation des règles ET Open :



V. Étape 4 — Démarrage de Suricata

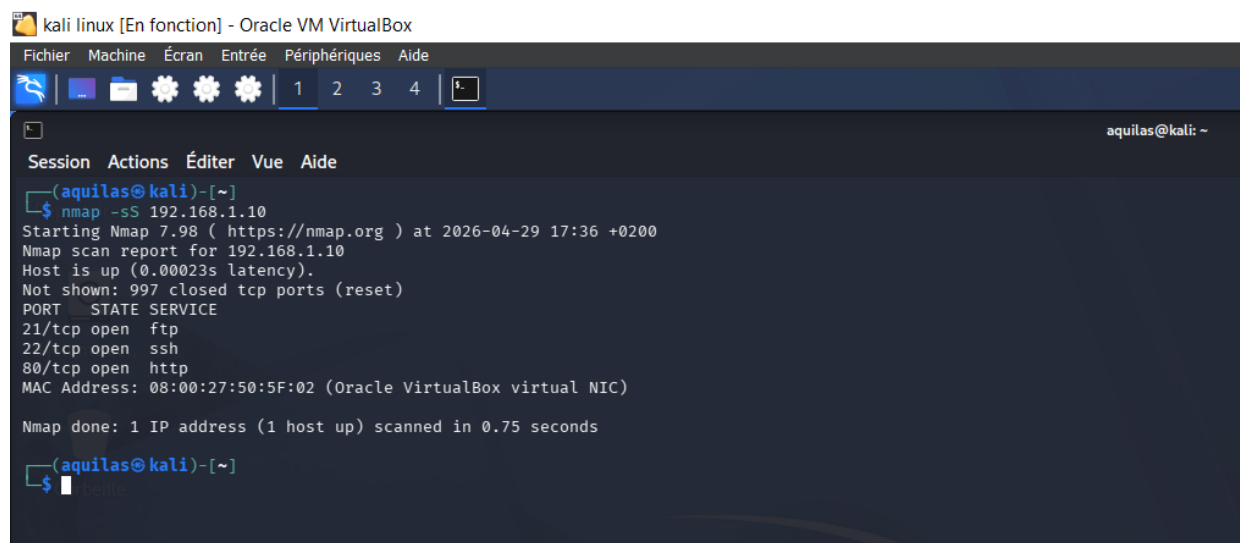
Navigation : Services → Suricata → Interfaces

Activation de Suricata sur l'interface LAN.

VI. Étape 5 — Génération d'une attaque

nmap -sS 192.168.1.10

Capture d'écran — Exécution du scan Nmap depuis Kali :



Interprétation

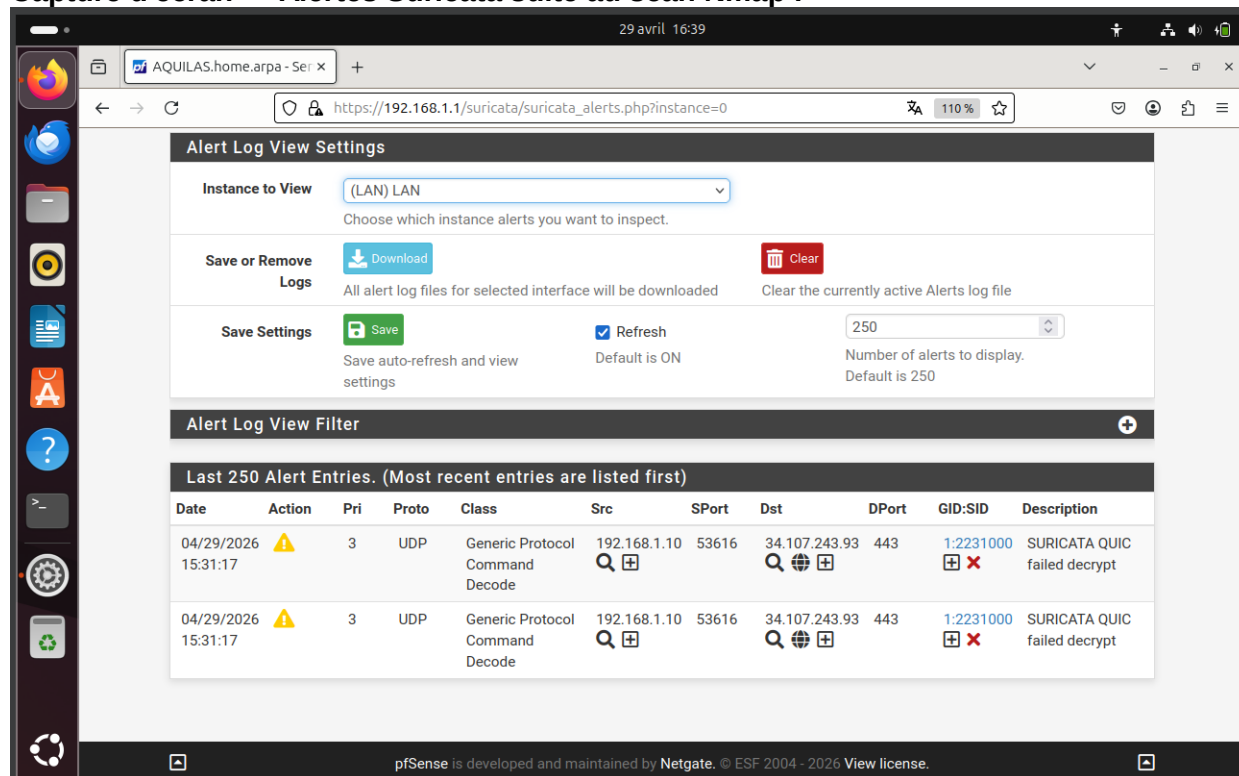
Suricata a détecté l'activité suspecte en comparant le trafic à ses signatures. En mode IDS, le trafic n'est pas bloqué : l'administrateur est alerté mais ne réagit pas automatiquement.

VII. Étape 6 — Analyse des alertes

Navigation : Services → Suricata → Alerts

Des alertes correspondant au scan doivent apparaître.

Capture d'écran — Alertes Suricata suite au scan Nmap :



VIII. Étape 7 — Simulation d'une attaque plus avancée

Lancement de l'attaque :

```
msfconsole
```

```
use exploit/windows/smb/ms17_010_eternalblue
```

```
set RHOSTS 192.168.1.10
```

```
run
```

Alertes critiques

Signature	Sévérité
-----------	----------

ET EXPLOIT EternalBlue MS17-010	Élevée
---------------------------------	--------

ET SHELLCODE Possible SMB exploit	Critique
-----------------------------------	----------

Capture d'écran — Attaque Metasploit et alertes Suricata :

The image shows two screenshots. The top screenshot is a terminal window running Metasploit (msf) on a Kali Linux VM. It displays the Metasploit framework version 6.0.130-dev and a list of available exploits. The user has entered the command 'use exploit/windows/smb/ms17_010_eternalblue' and 'set RHOSTS 192.168.1.20'. The session shows the execution of the exploit, which successfully connects to the target and triggers a 'failed decrypt' alert from Suricata.

The bottom screenshot is a web browser window showing the Suricata alert log at https://192.168.1.1/suricata/suricata_alerts.php?instance=0. The log displays several alerts triggered by the attack, all identified as 'SURICATA QUIC failed decrypt'.

Date	Time	Severity	Count	Protocol	Source IP	Source Port	Destination IP	Destination Port	Signature	Action
04/29/2026	15:43:45	Warning	3	UDP	192.168.1.10	50979	142.250.140.95	443	1:2231000 SURICATA QUIC failed decrypt	Failed decrypt
04/29/2026	15:43:45	Warning	3	UDP	192.168.1.10	50979	142.250.140.95	443	1:2231000 SURICATA QUIC failed decrypt	Failed decrypt
04/29/2026	15:43:45	Warning	3	UDP	142.250.140.95	443	192.168.1.10	50979	1:2231000 SURICATA QUIC failed decrypt	Failed decrypt
04/29/2026	15:43:45	Warning	3	UDP	142.250.140.95	443	192.168.1.10	50979	1:2231000 SURICATA QUIC failed decrypt	Failed decrypt
04/29/2026	15:43:45	Warning	3	UDP	142.250.140.95	443	192.168.1.10	50979	1:2231000 SURICATA QUIC failed decrypt	Failed decrypt
04/29/2026	15:31:17	Warning	3	UDP	192.168.1.10	53616	34.107.243.93	443	1:2231000 SURICATA QUIC failed decrypt	Failed decrypt

Interprétation

Suricata détecte aussi les comportements malveillants avancés grâce à des signatures spécifiques.

Attaque par brute force ssh

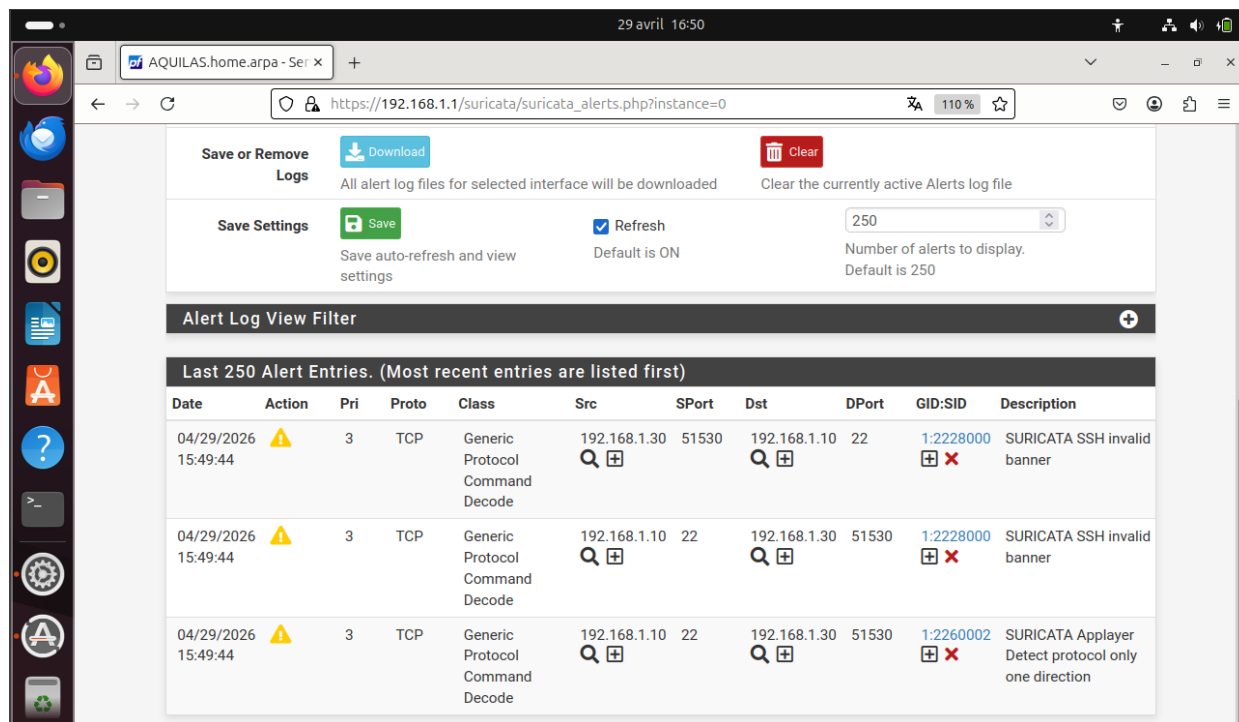
```

kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide

Session Actions Éditer Vue Aide

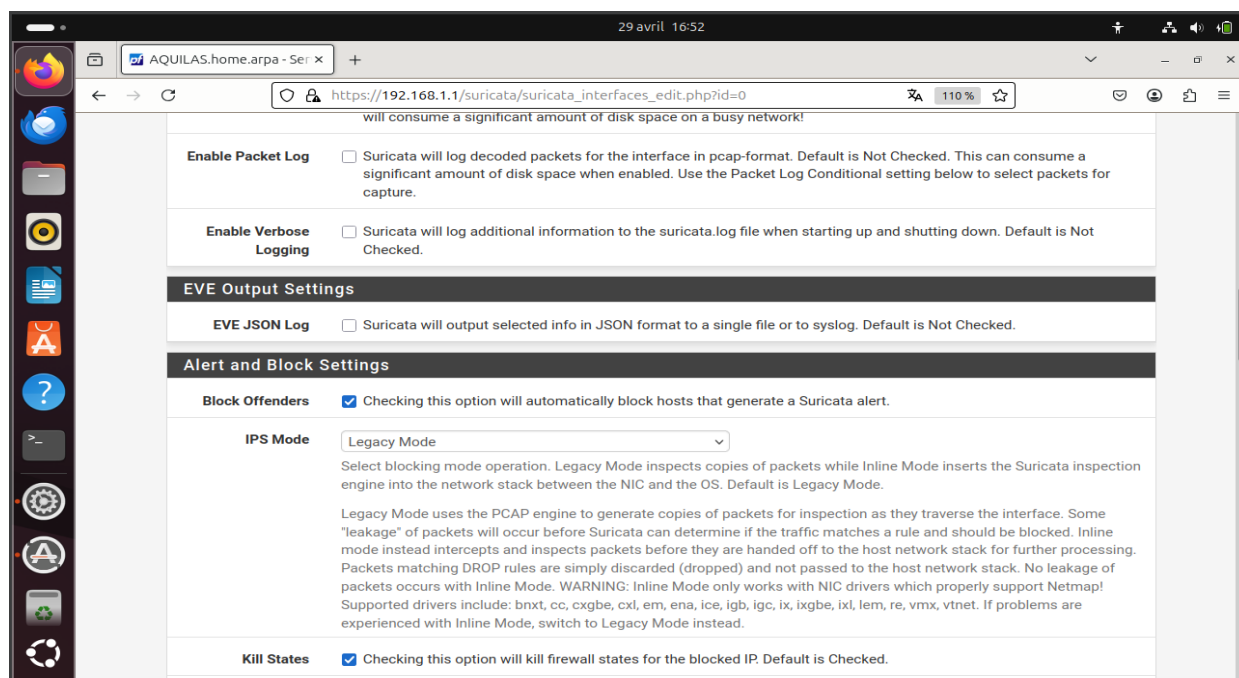
aquilas@kali: ~
$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -i to skip waiting)) from a previous session found, to prevent overwriting. ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.1.10:22/
[22][ssh] host: 192.168.1.10 login: student password: 123456
1 of 1 target successfully completed, 1 valid password found
[WARNING] writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-29 17:49:47
    
```

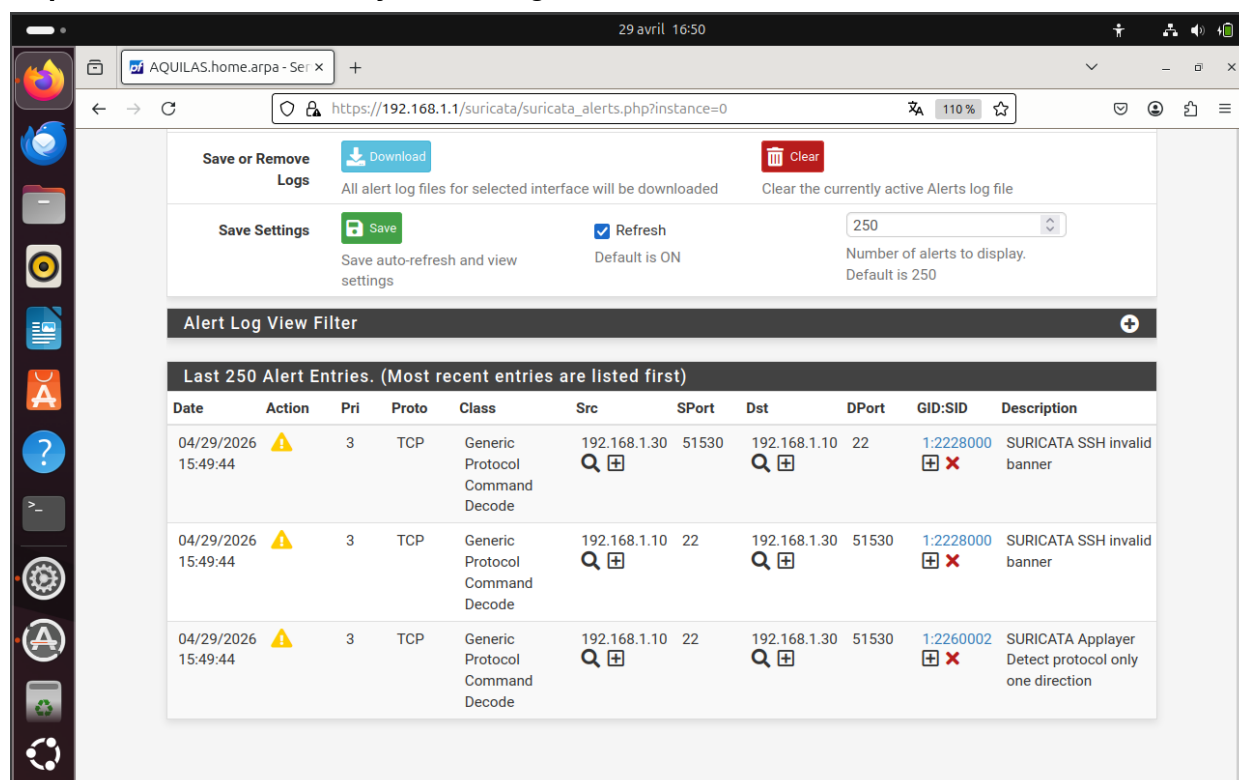


IX. Étape 8 — Passage en mode blocage (IPS)

Capture d'écran — Mode IPS activé (Block Offenders) :



Capture d'écran — mise a jour des regles :



X. Analyse théorique

A. Comment Suricata détecte-t-il une attaque ?

Suricata analyse en temps réel les paquets réseau qui transitent par l'interface surveillée. Il compare chaque paquet à sa base de signatures (règles). Quand un paquet correspond à une règle connue (ex. : un scan SYN Nmap), Suricata génère une alerte et, en mode IPS, peut bloquer la connexion.

B. Différence entre IDS et IPS

Critère	IDS (Détection)	IPS (Prévention)
Rôle	Surveillance et alerte	Surveillance, alerte ET bloque
Action sur l'attaque	Aucune (passive)	Blocage actif (active)
Risque de faux positifs	Faible impact	Peut bloquer du trafic légitime
Cas d'usage	Audit, surveillance	Protection en temps réel

C. L'intérêt des signatures

Les signatures sont le cœur du système de détection. Ce sont des règles précises qui décrivent des comportements malveillants connus. Elles permettent à Suricata de reconnaître automatiquement :

- Un scan Nmap (reconnaissance)

- Une attaque brute force
- Des exploitations connues (CVE)
- Du trafic de malware

Sans signatures, Suricata ne saurait pas quoi chercher. La mise à jour régulière de ces règles (ex. Emerging Threats) est donc essentielle.

XI. Options avancées de Suricata

A. Types de règles

- ET Open (Emerging Threats) : règles communautaires gratuites, mises à jour régulièrement
- ET Pro : version payante avec règles plus récentes
- Règles personnalisées : l'administrateur peut créer ses propres signatures

B. Niveaux de sévérité

Chaque alerte Suricata possède un niveau de priorité (1 = critique, 4 = informationnel). Cela permet à l'administrateur de filtrer les alertes et de se concentrer sur les plus importantes.

C. Filtrage des alertes

Il est possible de supprimer les faux positifs via des règles de suppression, ou de créer des listes blanches pour exclure certains hôtes ou types de trafic du déclenchement d'alertes.

XII. Conclusion

Dans ce TP, nous avons ajouté une couche d'intelligence à notre réseau. Nous avons compris que :

- Un pare-feu contrôle les flux
- Un IDS/IPS analyse les comportements
- Les deux sont complémentaires

À l'issue de ce travail pratique, nous avons acquis les compétences suivantes :

- Surveiller un réseau en temps réel
- Détecter des comportements anormaux
- Réagir face à une attaque

Ce système est très proche de ce qui est utilisé dans les SOC (Security Operations Centers) modernes, ce qui confirme la valeur opérationnelle de cette formation.